

M3 - W10D4 - Simulazione fase di raccolta informazioni

Traccia

Utilizzare alcuni degli strumenti presenti all'interno della pagina relativa al seguente link:

<https://www.yeahhub.com/15-most-useful-host-scanning-commands-kalilinux/>

per raccogliere informazioni sulla macchina Metasploitable e produrre un report.

Introduzione

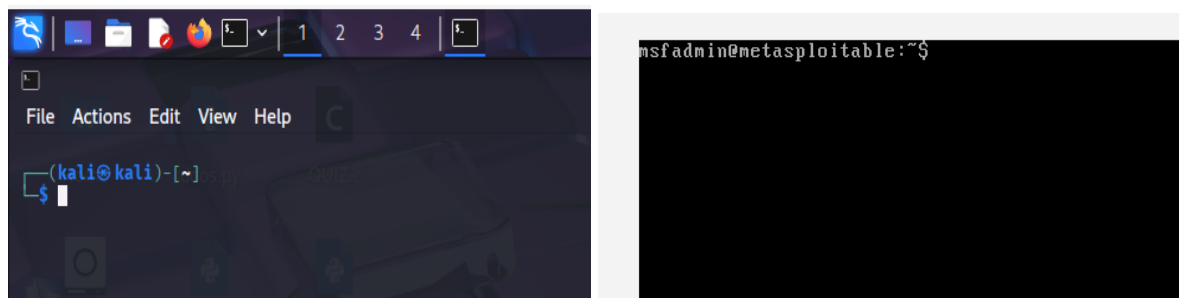
La fase di **Information Gathering** è il passaggio preliminare e fondamentale di qualsiasi penetration test. Il suo **obiettivo primario** è quello di **raccogliere il maggior volume possibile di dati** sul sistema, sulla rete o sull'organizzazione bersaglio. Questa raccolta di informazioni è essenziale per:

- **Comprendere la superficie di attacco:** Identificare host, servizi attivi, porte aperte, versioni software, indirizzi IP, domini, sottodomini e potenziali vulnerabilità.
- **Pianificare l'attacco:** Utilizzare le informazioni ottenute per modellare un piano di attacco mirato ed efficace, aumentando le probabilità di successo nella fase di sfruttamento.

Il link fornito nell'esercizio introduce una lista degli **strumenti più diffusi e impiegati** per l'Information Gathering.

Procedimento

Di seguito, dopo aver avviato le macchine virtuali Kali Linux e Meta, apriamo il terminale sulla prima per iniziare l'esercizio. Useremo alcuni degli strumenti forniti dal link.

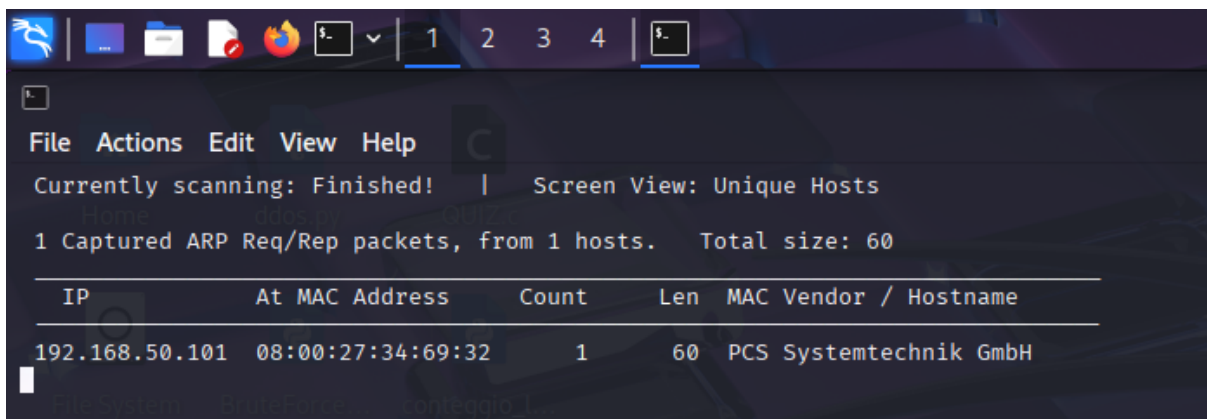


1° strumento: netdiscover -r 192.168.50.101

L'immagine mostra che tale comando esegue una scansione della rete utilizzando un protocollo ARP.

Nella tabella possiamo osservare:

- l'**indirizzo IP** della macchina target 192.168.50.101
- l'**indirizzo MAC** della macchina target 08:00:27:34:69:32
- **Count 1** : indica che è stato rilevato 1 pacchetto ARP
- **Len 60** : indica la dimensione del pacchetto ARP
- **MAC Vendor / Hostname** : indica il nome del produttore dell' interfaccia di rete



2° strumento: nmap -sS -sV -T4 192.168.50.101

L'obiettivo principale di questo comando è identificare le porte aperte sul target e determinare software e versione dei servizi in ascolto.

I comandi che vengono utilizzati sono:

- **nmap** : eseguibile di Nmap
- **-sS** : per effettuare una scansione "stealth" delle porte, ovvero una scansione che rileva le porte aperte anche senza terminare il **three-way handshake**. Questo tipo di scansione invia un pacchetto **SYN** e attende la risposta. Se riceve un **SYN/ACK**, considera la porta come **aperta**.
- **-sV** : per abilitare la rilevazione della versione del servizio/applicazione in ascolto su una determinata porta.
- **-T4** : opzione di timing relativa alla scala T0 - T6 di Nmap. Questi Timing Template vanno dal più lento e discreto, T0, (difficilmente rilevabile da firewall) a quello più veloce e aggressivo, T6, (facilmente rilevabile da

firewall). Il template utilizzato, ovvero il T4, risulta essere un buon compromesso per velocità e affidabilità, ciò nonostante, esso ha una maggiore possibilità di essere rilevato da Firewall o IDS.

- **192.168.50.101** : indirizzo IP target

```
(kali@kali)~$ nmap -sS -sV -T4 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 05:26 EST
Nmap scan report for 192.168.50.101
Host is up (0.00057s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?         Netkit rshd
514/tcp   open  shell          GNU Classpath grmiregistry
1099/tcp  open  java-rmi       Metasploitable root shell
1524/tcp  open  bindshell      2-4 (RPC #100003)
2049/tcp  open  nfs            ProFTPD 1.3.1
2121/tcp  open  ftp            MySQL 5.0.51a-3ubuntu5
3306/tcp  open  mysql          PostgreSQL DB 8.3.0 - 8.3.7
5432/tcp  open  postgresql     VNC (protocol 3.3)
5900/tcp  open  vnc            (access denied)
6000/tcp  open  X11            UnrealIRCd
6667/tcp  open  irc            Apache Jserv (Protocol v1.3)
8009/tcp  open  ajp13          unknown
8180/tcp  open  unknown
MAC Address: 08:00:27:34:69:32 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 190.30 seconds
```

L'immagine mostra che questa scansione ha identificato **20 porte TCP aperte**, rivelando i **servizi** in esecuzione su ciascuna porta (es. FTP, SSH, Telnet, HTTP) e le relative **versioni** (es. vsftpd 2.3.4, OpenSSH 4.7p1)

3° strumento: nc -nvz 192.168.50.101 1-1024

Questo comando utilizza **Netcat (nc)**, un utility fondamentale per eseguire una scansione di porte su un target specifico.

I comandi che vengono utilizzati sono:

- **nc** : eseguibile di netcat
- **-nvz** : per eseguire una scansione veloce delle porte (**-z**), utilizzando direttamente gli indirizzi IP senza risoluzione DNS (**-n**) e visualizzando i risultati dettagliati (**-v**) per indicare quali porte sono aperte o chiuse.
- **192.168.50.101** : indirizzo IP target
- **1-1024** : Specifica l'intervallo di porte da scansionare, in questo caso le prime 1024 porte.

L'output del comando mostrerà tutte le porte all'interno dell'intervallo **1-1024** su cui il target **192.168.50.101** ha un servizio attivo.

```
(kali㉿kali)-[~]  
$ nc -nvz 192.168.50.101 1-1024  
(UNKNOWN) [192.168.50.101] 514 (shell) open  
(UNKNOWN) [192.168.50.101] 513 (login) open  
(UNKNOWN) [192.168.50.101] 512 (exec) open  
(UNKNOWN) [192.168.50.101] 445 (microsoft-ds) open  
(UNKNOWN) [192.168.50.101] 139 (netbios-ssn) open  
(UNKNOWN) [192.168.50.101] 111 (sunrpc) open  
(UNKNOWN) [192.168.50.101] 80 (http) open  
(UNKNOWN) [192.168.50.101] 53 (domain) open  
(UNKNOWN) [192.168.50.101] 25 (smtp) open  
(UNKNOWN) [192.168.50.101] 23 (telnet) open  
(UNKNOWN) [192.168.50.101] 22 (ssh) open  
(UNKNOWN) [192.168.50.101] 21 (ftp) open
```

L'immagine mostra che questa scansione ha rilevato le **porte aperte** nell'intervallo **da 1 a 1024** (es. 21, 22, 23, ...) e i relativi **servizi in ascolto** su ciascuna porta (es. SSH, FTP, ...)